

GRC Vulnerability Classification Framework

v0.4.9

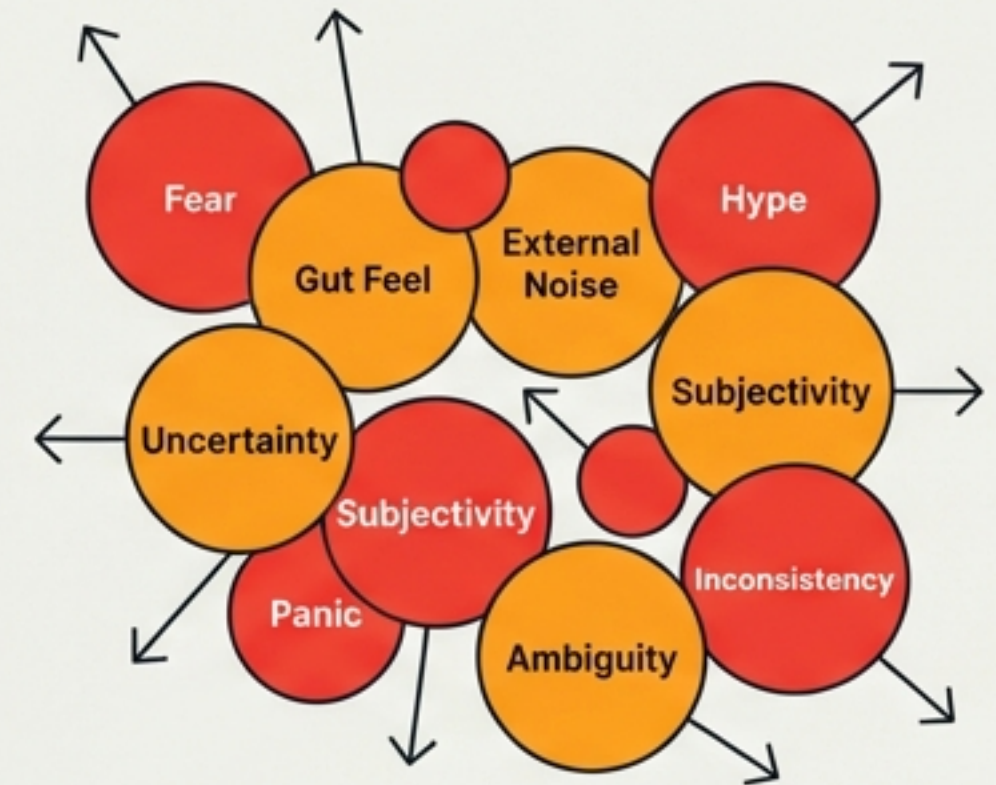


Replacing Theory with Pragmatism.

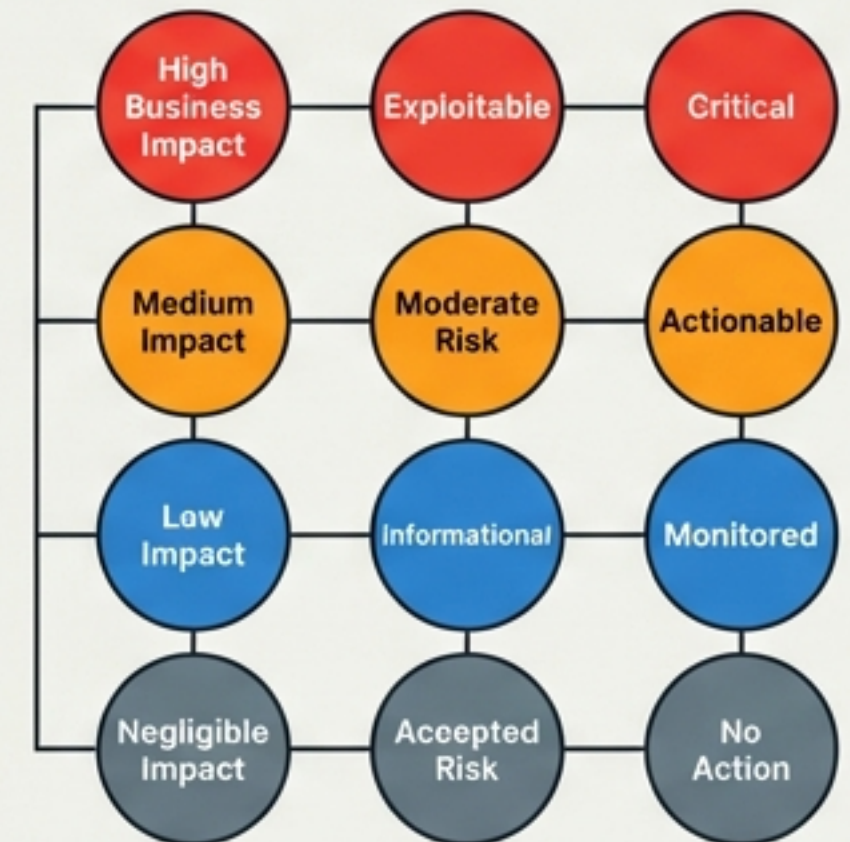
We are moving away from theoretical exploitability to a rigorous assessment of actual business impact.
A critical-sounding vulnerability with zero real-world impact is not a Critical vulnerability.

- 01. Standardise the Scale:** A unified P0–P10 severity gauge.
- 02. Operationalise Decisions:** A 'Risk Decision Matrix' to remove ambiguity.
- 03. Codify Counter-Risks:** Recognising that the 'Risk of the Fix' is a valid operational counter-weight.

BEFORE



AFTER



Matrix Processed

The Five Rules of Engagement.

01 /

Business Impact > Theory

Severity is determined by what actually happens if exploited. If it does not hurt the business, it is not Critical.

02 /

Architecture is Mitigation

SG/Send is Zero-Knowledge. The server stores only encrypted bytes. This is a permanent structural shield.

03 /

Preconditions Matter

We explicitly count the hurdles (timing, tokens, network position) an attacker must jump.

04 /

The Fix is a Risk

Complex fixes introduce new bugs. "Accept with monitoring" is often safer than "add complexity."

05 /

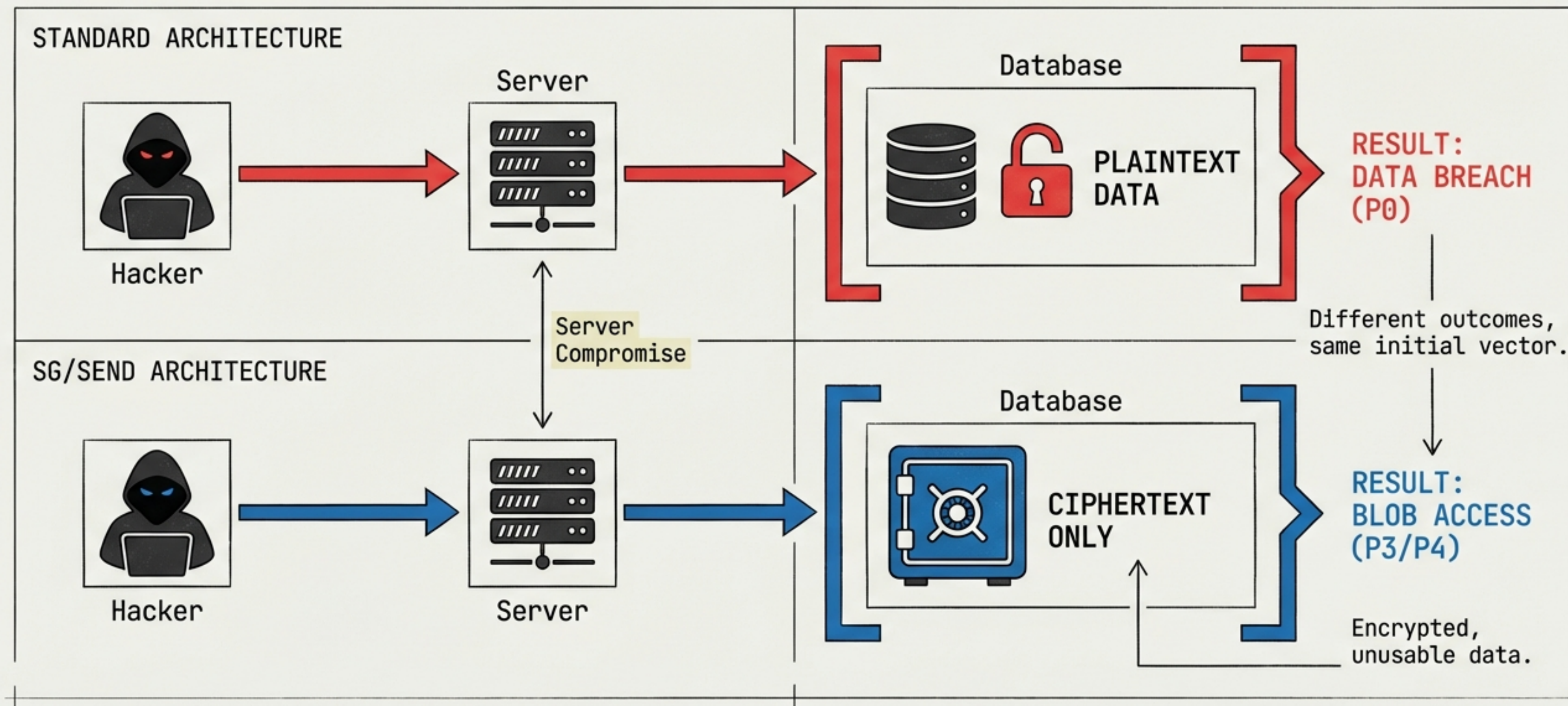
Known vs. Unknown

A known gap is a deliberate decision (process worked). An unknown gap is a process failure.

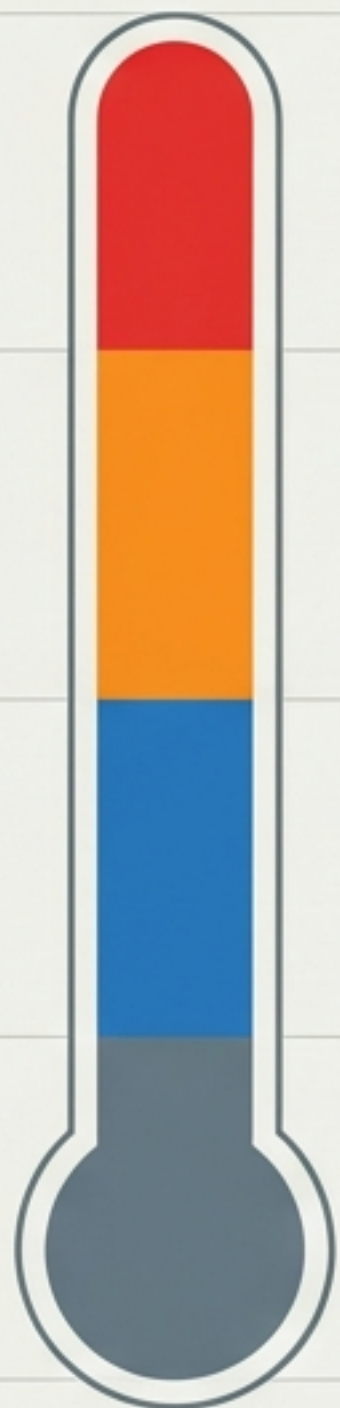


The Zero-Knowledge Advantage.

Why Our “Critical” is Different.



The Unified Severity Scale (P0–P10).



CRISIS TIER

P0 - Total Crisis
P1 - Major Incident

Immediate drop-everything
response. Active exploitation.

IMPACT TIER

P2 - Significant
P3 - Must Fix

Real user impact.
Fix before production.

IMPROVEMENT TIER

P4 - Should Fix
P5 - Convenient
P6 - Minor

Good practice,
defence-in-depth,
supply chain.

NOISE TIER

P7 - Cosmetic
P8 - Negligible
P9 - Info
P10 - N/A

Theoretical, cosmetic,
or superseded.

This scale is the
common language
between Engineering,
Product, and GRC.

When to Stop the Line (P0–P3).

 P0: Total Crisis	Definition: Active exploitation. Plaintext breach. Loss of zero-knowledge.	Example: Decryption keys leaked to server.
P1: Major Incident	Definition: Data at risk. Infrastructure compromised. Response in hours.	Example: Admin credentials compromised with real user data present.
 P2: Significant	Definition: Likely customer impact. Realistic preconditions.	Example: XSS with confirmed exfiltration path.
P3: Must Fix	Definition: Pre-production vulnerability that would be fatal in prod.	Auth bypass in staging.

Managing Debt and Distractions (P4–P10).

IMPROVEMENT TIER (P4–P6)

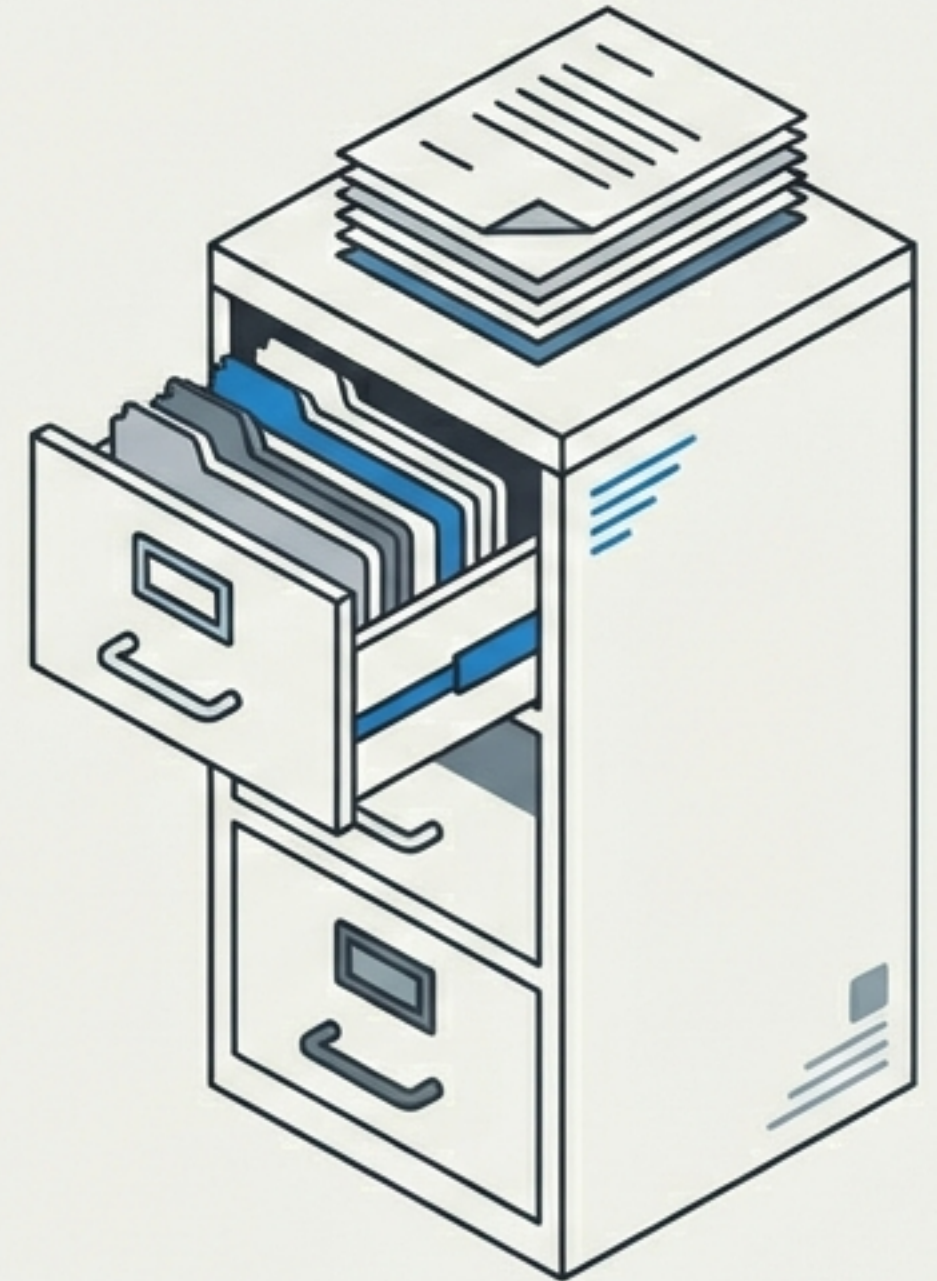
DECISION: Backlog or Next Sprint

Supply chain risks (mitigated by lockfile)
Missing security headers
Defence-in-depth gaps

NOISE TIER (P7–P10)

DECISION: Monitor or Ignore

Theoretical overflows
Edge cases requiring admin keys
Code style / cosmetic issues



The Matrix Part I: Assessing Impact & Access.

Q1: IMPACT (The Floor)

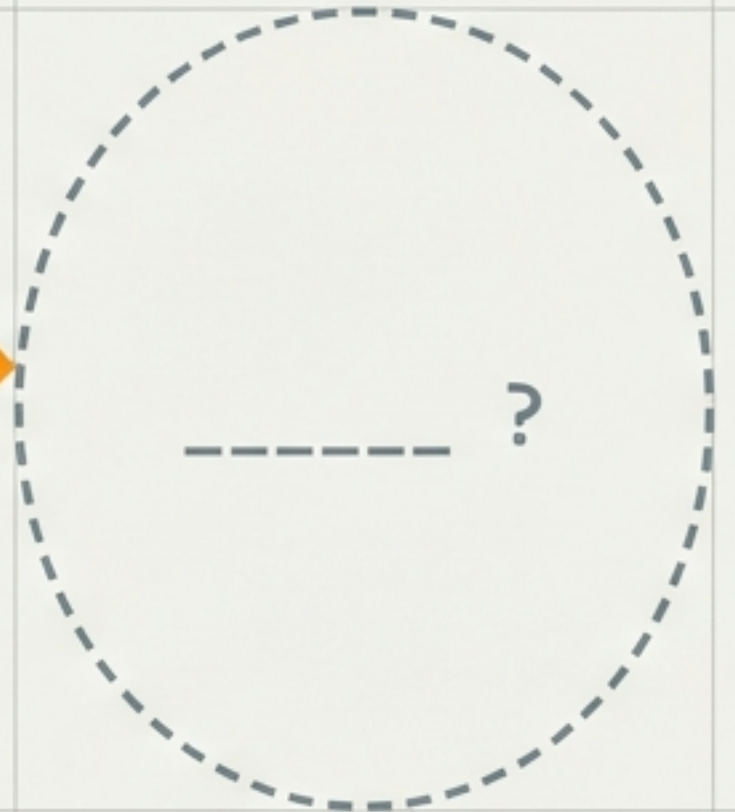
- Plaintext Breach
(Start at **P0**)
- Encrypted Data Only
(Cap at **P3/P4**)
- Metadata Only
(Start at **P5**)



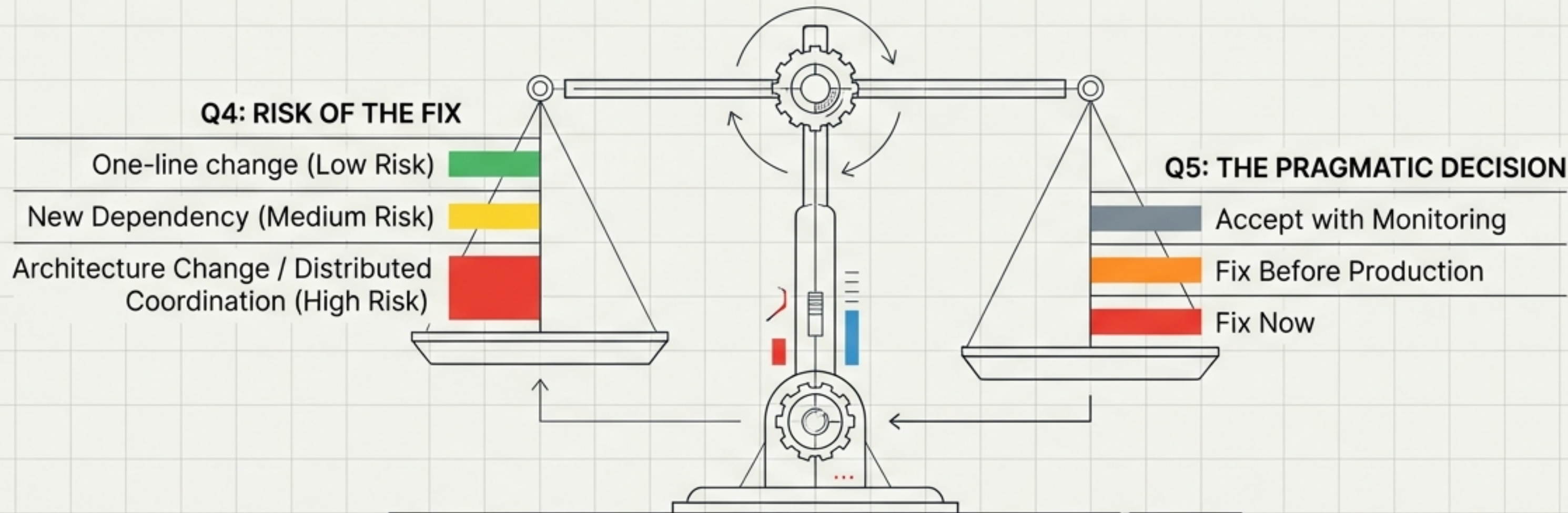
Q2: PRECONDITIONS (The Discount)

- 0 Preconditions:
No Change
- 1 Precondition
(Token/Timing):
-1 Level
- 3+ Preconditions:
-2 to -3 Levels

PROVISIONAL SCORE



The Matrix Part II: The Cost of Action.



“Distributed systems bugs can be worse than the original vulnerability.”

Mapping External Noise to Internal Signal.

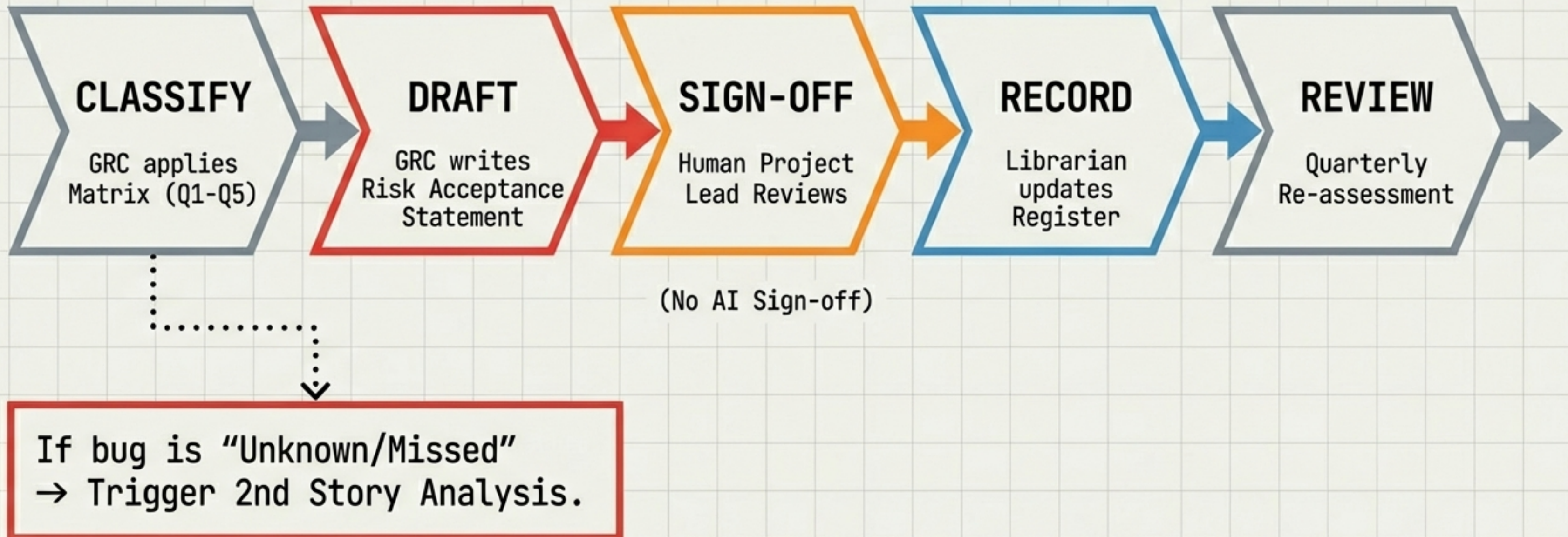
Translation Table

EXTERNAL RATING	THE FILTER		INTERNAL REALITY
CRITICAL (RCE)			P2-P4 (Data is Encrypted)
HIGH (Auth Bypass)			P3 (No Plaintext on Server)
LOW (Best Practice)			P6-P8 (Backlog)

CRUCIAL EXCEPTION: Client-Side Vulnerabilities.

Rule: Client-side bugs **DO NOT** get the discount. The browser has the plaintext.

The Risk Acceptance Lifecycle.



Framework in Action: INC-002.

INCIDENT REPORT DATA.

- Incident: INC-002
- Date: 2026-02-17
- › Total Findings Processed: 29

CASE STUDY: Finding #1 (Token Race Condition).

Analysis:
Flagged for Deep Analysis.

Conflict Equation:
Risk of Fix (Architectural Complexity) >
Vulnerability Risk (Quota Bypass)

Outcome:
⚠ Accept with Monitoring.

Security is not about fixing everything. It is about fixing the right things.

Link: <library/sgraph-send/incidents/2026-02-17-security-review/>